Relatório Técnico de Governança de TI (COBIT 2019) e Conformidade LGPD

Plataforma Integrada de Gestão de Riscos e Desastres: Defesa em Foco

Docente Responsável: Profª Letícia

Data de Entrega: Novembro de 2026

Equipe de Desenvolvimento: Reinaldo Morais dos Santos & Grupo BRAOTI2

Status do Projeto: Em Produção / Infraestrutura Swarm Ativa

1. Resumo do Projeto BRAOTI2 (Defesa em Foco)

O **Defesa em Foco** é uma plataforma integrada de tecnologia e inovação comunitária voltada à modernização dos processos de triagem, comunicação rápida e resposta a desastres naturais e eventos climáticos extremos (como enchentes, enxurradas, deslizamentos e queimadas). Desenvolvido no escopo da disciplina interdisciplinar BRAOTI2, o projeto atua diretamente na articulação entre a sociedade civil e os órgãos municipais de Defesa Civil.

O ecossistema divide-se em três pilares arquiteturais:

- **Aplicativo Móvel Comunitário (Flutter):** Disponibilizado para cidadãos em Android e iOS, operando com *resiliência offline total* (armazenamento local via Hive e mapas vetoriais cacheados pelo FMTC). Permite o envio de ocorrências com coordenadas georreferenciadas e fotos, além de receber alertas com sirenes e rotas de fuga.
- **Sala de Situação e Dashboard Web (Spring Boot 3 + Flutter Web):** Painel de comando operacional para coordenadores da Defesa Civil. Integra Inteligência Artificial Multimodal (Google Gemini) para auditoria e agrupamento espacial com o banco relacional **PostGIS**, reduzindo duplicidades e acionando equipes de rua.
- **Infraestrutura Distribuída (Docker Swarm On-Premises):** Cluster em alta disponibilidade distribuído em 3 nós (colima manager e workers DinD), balanceador de carga reverso Nginx, armazenamento de objetos MinIO e comunicação segura criptografada via túneis Cloudflare (Zero Trust).

2. Mapeamento aos Objetivos de Negócio e de TI (COBIT Goals Cascade)

A governança eficaz exige que toda decisão tecnológica decorra diretamente de uma meta da organização. Utilizando o desdobramento de metas do framework COBIT 2019, estruturamos os seguintes alinhamentos:

OBJETIVOS DE NEGÓCIO / EXTENSÃO PÚBLICA (ON)	OBJETIVOS DE TI ALINHADOS (OT)
ON-01 (Salvar Vidas e Mitigar Danos): Reduzir em até 40% o tempo médio decorrido entre a emissão do relato pelo cidadão e o despacho da equipe de rua.	**OT-01 (Automação e Triagem Inteligente):** Implementação de clusters espaciais (PostGIS `ST_DWithin`) e auditoria rápida via IA Multimodal para validação imediata do sinistro.
ON-02 (Continuidade e Confiabilidade Operacional): Garantir que o canal de socorro funcione ininterruptamente durante eventos climáticos severos e apagões parciais.	**OT-02 (Alta Disponibilidade e Operação Offline):** Cluster Swarm distribuído em múltiplos nós com réplicas ativas e aplicativo móvel com sincronização assíncrona automática.
ON-03 (Conformidade, Governança e Transparência): Assegurar conformidade integral com a LGPD (Lei nº 13.709/18) e padronização com o protocolo nacional COBRADE da Defesa Civil.	**OT-03 (Segurança, Privacidade e Interoperabilidade):** Criptografia ponta a ponta (TLS/BCrypt), autenticação JWT Stateless, controle de acesso RBAC e rotinas de exportação CSV padronizadas.

3. Processos do Framework COBIT 2019 Selecionados

Para estabelecer um modelo de governança completo, foram selecionados **2 processos da Camada de Governança (EDM)** e **4 processos da Camada de Gestão (APO, DSS, MEA)**:

3.1 Camada de Governança

EDM01 **Garantir a Configuração e Manutenção do Framework de Governança:** Responsável por estruturar o modelo de tomada de decisões, transparência pública e definição de autoridades entre prefeituras consorciadas, Defesa Civil e a equipe de TI.

EDM03 **Garantir a Otimização de Riscos:** Fixa os limites de apetite e tolerância ao risco do município, assegurando que falhas tecnológicas, perda de dados ou indisponibilidade de infraestrutura não inviabilizem operações de salvamento humano.

3.2 Camada de Gestão

APO12 **Gerenciar Riscos:** Identifica riscos técnicos operacionais (como cotas da API de IA atingidas ou queda de sinal de telefonia móvel) e implementa planos práticos de mitigação (cache no Hive e fallback de centroid PostGIS).

APO13 **Gerenciar Segurança da Informação:** Estabelece controles cibernéticos de defesa, políticas de acesso por papéis (RBAC: Cidadão, Agente, Coordenador), hashing BCrypt e proteção de borda contra ataques maliciosos via `RateLimitingFilter`.

DSS01 **Gerenciar Operações:** Garante o funcionamento rotineiro dos servidores, volumes de dados, balanceador Nginx e execução dos scripts de *watchdog* para recuperação imediata de containers e serviços do Swarm.

MEA01 **Monitorar, Avaliar e Medir Desempenho e Conformidade:** Acompanha métricas e SLAs de atendimento, taxa de sucesso de entregas de notificações push e audita a conformidade do software junto à LGPD e normas da ANPD.

4. Avaliação do Nível de Capacidade dos Processos (COBIT 2019 / CMMI)

A maturidade foi avaliada na escala padrão de **Nível 0 (Incompleto) a Nível 5 (Otimizado)**, confrontando a situação atual do projeto com as metas e planos de evolução técnica:

PROCESSO	ATUAL	ALVO	EVIDÊNCIAS REAIS NO PROJETO DEFESA EM FOCO	LACUNAS E AÇÕES DE MELHORIA
EDM01 (Governança)	**Nível 2**	**Nível 3**	RBAC rígido implementado no Spring Boot; papéis e permissões documentados; repositório Git com governança de branches.	Falta institucionalização de comitê formal intermunicipal. *Ação:* Criar termo de governança com municípios parceiros.
EDM03 (Riscos Gov)	**Nível 2**	**Nível 4**	Arquitetura de tolerância a falhas implementada (failover PostGIS e planos de contingência técnica documentados).	Ausência de matriz quantitativa de impacto financeiro. *Ação:* Elaborar painel de risco formal com limites de tolerância.
APO12 (Gestão Riscos)	**Nível 3**	**Nível 4**	Resiliência ativa comprovada: app armazena ocorrências sem sinal e dispara sincronização via `SyncNavigatorObserver`.	Testes de estresse executados manualmente. *Ação:* Inserir testes de carga contínuos (k6/JMeter) na esteira de integração.
APO13 (Segurança)	**Nível 3**	**Nível 4**	Senhas criptografadas (BCrypt), JWT Stateless, SSL/TLS de ponta a ponta e Política de Privacidade publicada.	Acesso administrativo sem segundo fator. *Ação:* Implementar 2FA obrigatório (TOTP) para Coordenadores.
DSS01 (Operações)	**Nível 3**	**Nível 4**	Cluster Swarm com 3 nós ativos, watchdog automatizado em bash, balanceamento Nginx e Docker Visualizer.	Métricas dispersas em logs. *Ação:* Implantar stack Prometheus + Grafana com alertas imediatos no Telegram.
MEA01 (Conformidade)	**Nível 2**	**Nível 3**	Exportação de relatórios oficiais COBRADE e monitoramento de saúde via Spring Boot Actuator (`/health`).	Auditorias manuais periódicas. *Ação:* Criar dashboard de SLA de atendimento com metas de tempo por bairro.

5. Matriz RACI dos Processos de Governança e Gestão

Define com exatidão as atribuições entre os papéis: **Cidadão (CID)**, **Agente de Campo (AGE)**, **Coordenador Defesa Civil (COO)**, **Equipe de TI/Dev (DEV)** e **Encarregado de Dados (DPO)**:

PROCESSO / ATIVIDADE CHAVE	CID	AGE	COO	DEV	DPO
EDM01: Definir diretrizes estratégicas e prioridades de TI	I	C	A	R	C
EDM03: Definir apetite de risco e continuidade operacional	I	C	A	C	R
APO12: Monitorar contingências técnicas e falhas de rede	I	I	C	R/A	C
APO13: Gerenciar segurança cibernética e auditoria de acessos	I	I	C	R	A
DSS01: Operar cluster Swarm, rotinas de backup e failover	I	I	I	R/A	I
MEA01: Medir tempo de resposta (SLAs) e conformidade LGPD	I	C	A	R	A
Operação: Registro de ocorrência com GPS e fotografia	R	I	I	I	I
Operação: Triagem e validação com IA / PostGIS	I	C	A	R	I
Operação: Atendimento presencial e despacho de socorro	I	R	A	I	I

Legenda: R = Responsible (Executor); A = Accountable (Aprovador/Responsável Final); C = Consulted (Consultado); I = Informed (Informado).

6. Análise de Conformidade com a LGPD (Lei Federal nº 13.709/2018)

6.1 Mapeamento e Bases Legais Aplicadas (Artigo 7º da LGPD)

DADO PESSOAL TRATADO	CLASSIFICAÇÃO	FINALIDADE OPERACIONAL	BASE LEGAL APLICÁVEL
Nome Completo	Dado Pessoal Comum	Identificação do comunicante e prestação de contas à Defesa Civil	Art. 7º, V (Execução de contrato/serviço público)
E-mail e Telefone	Dado Pessoal Comum	Contato emergencial para confirmação de fatos e autenticação no sistema	Art. 7º, V (Execução de contrato)
Senha Cadastral	Dado Pessoal de Acesso	Controle de acesso autenticado (criptografada via hash BCrypt)	Art. 7º, V (Segurança de sistemas)
Geolocalização GPS	Dado Pessoal Geográfico	Determinação do local exato do desastre para envio imediato de viaturas	**Art. 7º, VII (Proteção da vida e incolumidade física)**
Fotos do Incidente	Dado Multimodal / Imagem	Auditoria visual do estrago e classificação pelo modelo de IA Gemini	**Art. 7º, VII (Proteção da vida)** c/c Art. 7º, I
Token Push (FCM)	Dado Técnico Identificador	Disparo imediato de sirenes digitais e ordens de evacuação por bairro	**Art. 7º, VII (Proteção da vida e socorro público)**

> ⚖️ **Destino Jurídico Estratégico: O Artigo 7º, Inciso VII da LGPD**
> Em situações extremas de desastres naturais (alagamentos repentinos, desabamentos de encostas e soterramentos), o consentimento prévio formal torna-se juridicamente secundário perante o **Art. 7º, Inciso VII da Lei 13.709/18: "para a proteção da vida ou da incolumidade física do titular ou de terceiro"**. Esse dispositivo confere legitimidade inatacável à atuação rápida do Defesa em Foco em conjunto com os órgãos oficiais do município.

6.2 Riscos Identificados e Medidas de Controle Técnico

- **Risco 1: Exposição pública do endereço residencial de cidadãos denunciantes.**
  Controle: Os dados pessoais são anonimizados nas listagens públicas do app. O munícipe só vê a descrição da rua; nome, telefone e dados de contato são criptografados e acessíveis exclusivamente por Coordenadores com perfil autorizado no banco.
- **Risco 2: Captura acidental de faces de vítimas ou de terceiros em fotografias.**
  Controle: As imagens residem no MinIO com URLs assinadas e tempo de expiração curto. Está em implementação pipeline com a API Gemini para aplicação automática de desfoque (*blur*) facial preventivo.
- **Risco 3: Exercício dos Direitos do Titular (Artigo 18 da LGPD).**
  Controle: Disponibilização expressa de canal oficial do Encarregado de Dados (DPO) através do e-mail

`reinaldoinfra07@gmail.com` na Política de Privacidade ativa, assegurando retificação e exclusão cadastral.

7. Plano de Melhorias e Roadmap de Governança (PDCA)

META / AÇÃO PROPOSTA	PROCESSO COBIT	PRAZO	RESPONSÁVEL	MÉTRICA / RESULTADO ESPERADO
M-01: Implementação de 2FA obrigatório (TOTP)	APO13	30 dias	DEV	100% dos coordenadores logando com segundo fator.
M-02: Pipeline de Testes de Estresse Automatizados (k6)	APO12 / DSS01	45 dias	DEV	Garantir 2.000 requisições/s sem perda de pacotes.
M-03: Monitoramento Centralizado (Prometheus/Grafana)	DSS01 / MEA01	60 dias	DEV	Alertas em tempo real via Telegram de integridade dos nós.
M-04: Elaboração do Relatório de Impacto Formal (RIPD)	EDM03 / MEA01	60 dias	DPO	Protocolo de conformidade documentado e validado.
M-05: Anonimização Facial Automática de Imagens	APO13	90 dias	DEV	Desfoque automático de faces humanas antes do MinIO.

8. Conclusões e Considerações Finais

A aplicação prática dos frameworks de Governança de TI (COBIT 2019) e dos preceitos da LGPD ao ecossistema do **Defesa em Foco** comprova que sistemas voltados a serviços essenciais exigem rigor que transcende a excelência de código. A governança proporcionou a garantia de que a arquitetura distribuída (Docker Swarm com 3 nós) opere com responsabilidade definida (Matriz RACI), com contingências estruturadas contra desastres de rede e sob amparo legal intransigente para a proteção da vida humana.

9. Referências Bibliográficas

1. ISACA. *COBIT 2019 Framework: Governance and Management Objectives*. Rolling Meadows, IL: ISACA, 2018.
2. BRASIL. *Lei Federal nº 13.709, de 14 de agosto de 2018*. Lei Geral de Proteção de Dados Pessoais (LGPD). Brasília, DF, 2018.
3. SECRETARIA NACIONAL DE PROTEÇÃO E DEFESA CIVIL (SEDEC). *Instrução Normativa sobre a Classificação e Codificação Brasileira de Desastres (COBRADE)*. Brasília: Ministério do Desenvolvimento Regional, 2023.
4. FERNANDO, Jeferson. *Descomplicando o Docker*. São Paulo: LINUXtips, 2022.
5. PROJETO DEFESA EM FOCO. *Documentação Oficial de Arquitetura e Engenharia de Software*. Repositório BRAOTI2, 2026.